

GRC BEGINNER ROADMAP

Governance · Risk · Compliance — Zero to Job-Ready

This roadmap is your step-by-step guide to breaking into GRC — one of the most in-demand cybersecurity domains. Each phase builds on the last. Take your time, use the free resources, and document everything.

GOVERNANCE	RISK	COMPLIANCE
Policies, strategy & leadership alignment	Identify, assess & treat threats to the org	Meet laws, regulations & standards

◆ PHASE 01 FOUNDATION — IT & Security Basics

■ 4–6 Weeks

■ Goal: Understand how computers, networks, and security fundamentals work before diving into GRC.

WHAT TO LEARN

■ Networking Basics

- OSI Model, TCP/IP, DNS, HTTP/S, Firewalls, VPNs

■ Operating Systems

- Windows AD, Linux CLI basics, user/group permissions

■ Security Concepts

- CIA Triad, AAA, threat actors, attack types, encryption 101

■ Cloud Intro

- AWS / Azure / GCP fundamentals — shared responsibility model

TARGET CERTIFICATIONS

- CompTIA IT Fundamentals (ITF+) [optional]
- Google IT Support Certificate (Coursera – free audit)

FREE RESOURCES & LINKS

→ Professor Messer (CompTIA A+ / Network+)

<https://www.professormesser.com>

→ Cybrary Free Courses

<https://www.cybrary.it>

→ NIST Glossary of Key Terms

<https://csrc.nist.gov/glossary>

→ TryHackMe — Pre-Security Path

<https://tryhackme.com/path/outline/presecurity>

→ Khan Academy — Internet 101

<https://www.khanacademy.org/computing/computers-and-internet>

◆ PHASE 02 GRC CORE — Frameworks & Standards

■ 6–8 Weeks

■ Goal: Learn the major frameworks companies use to govern security and meet compliance requirements.

WHAT TO LEARN

■ NIST Frameworks

- NIST CSF 2.0 — Govern, Identify, Protect, Detect, Respond, Recover
- NIST SP 800-53 — Security & Privacy Controls catalog
- NIST RMF — 7-step Risk Management Framework

■ ISO Standards

- ISO/IEC 27001 — ISMS structure & requirements
- ISO/IEC 27002 — Controls guidance
- Annex A controls overview

■ Compliance Frameworks

- SOC 2 Type I / II — Trust Service Criteria
- PCI-DSS — 12 requirements for payment data
- HIPAA — PHI safeguards (admin, physical, technical)
- GDPR basics — data subject rights, DPA role

■ Cloud-Specific

- CSA Cloud Controls Matrix (CCM)
- FedRAMP basics — US federal cloud standard

TARGET CERTIFICATIONS

- CompTIA Security+ (SY0-701)
- ISC2 CC — Certified in Cybersecurity (FREE exam voucher available)

FREE RESOURCES & LINKS

- NIST CSF 2.0 Official Doc (Free PDF)
<https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf>
- NIST SP 800-53 Rev5 (Free PDF)
<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r5.pdf>
- ISO 27001 Overview (Free)
<https://www.iso.org/isoiec-27001-information-security.html>
- AICPA SOC 2 Overview
<https://www.aicpa-cima.com/topic/audit-assurance/audit-and-assurance-greater-than-soc-2>
- HIPAA.gov — Free Training Materials
<https://www.hhs.gov/hipaa/for-professionals/training/index.html>
- CSA CCM (Free Download)
<https://cloudsecurityalliance.org/research/cloud-controls-matrix>
- ISC2 CC Free Course (Coursera)
<https://www.coursera.org/learn/isc2-systems-and-network-security>
- GDPR Full Text (EUR-Lex)
<https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX%3A32016R0679>

◆ PHASE 03 RISK MANAGEMENT

■ 4–6 Weeks

- Goal: Learn to identify, assess, prioritize, and treat risks using structured methodologies.

WHAT TO LEARN

■ Risk Concepts

- Threat, vulnerability, likelihood, impact
- Inherent risk vs residual risk
- Risk appetite vs risk tolerance

■ Risk Assessment Methods

- Qualitative (High / Med / Low matrices)
- Quantitative ($ALE = ARO \times SLE$)
- FAIR model introduction

■ Risk Treatment

- Accept · Avoid · Transfer · Mitigate
- Risk register creation & maintenance

■ Third-Party Risk

- Vendor risk questionnaires
- TPRM lifecycle basics

TARGET CERTIFICATIONS

- ISACA CRISC (advanced — aim for later)
- RIMS-CRMP (risk management path)

FREE RESOURCES & LINKS

- **NIST SP 800-30 Risk Assessment Guide (Free)**
<https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-30r1.pdf>
- **FAIR Institute — Free Resources**
<https://www.fairinstitute.org/resources>
- **ISACA Risk IT Framework (Free)**
<https://www.isaca.org/resources/isaca-journal/issues/2009/volume-6/the-risk-it-framework>
- **OCR HIPAA Risk Assessment Tool**
<https://www.healthit.gov/topic/privacy-security-and-hipaa/security-risk-assessment-tool>
- **ENISA Threat Landscape Reports (Free)**
<https://www.enisa.europa.eu/publications/enisa-threat-landscape-2024>

◆ PHASE 04 POLICIES, CONTROLS & AUDITING

■ 4–5 Weeks

■ *Goal: Learn how to write security policies, design controls, and prepare for/conduct audits.*

WHAT TO LEARN

■ Policy Writing

- Policy vs Standard vs Procedure vs Guideline
- Writing an Information Security Policy
- Acceptable Use, BYOD, Data Classification

■ Control Types

- Preventive · Detective · Corrective · Compensating
- Administrative · Physical · Technical

■ Audit Basics

- Internal vs external audits
- Evidence collection & gap analysis
- Audit lifecycle: planning → fieldwork → reporting

■ GRC Tooling

- ServiceNow GRC (demo available)
- OneTrust (free trial)
- Archer GRC concepts

TARGET CERTIFICATIONS

- CISA — Certified Information Systems Auditor (ISACA)
- ISO 27001 Lead Implementer / Auditor

FREE RESOURCES & LINKS

- **SANS Policy Templates (Free)**
<https://www.sans.org/information-security-policy/>
- **CIS Controls v8 (Free PDF)**
<https://www.cisecurity.org/controls/cis-controls-list>
- **IIA Internal Audit Standards (Free)**
<https://www.theiia.org/en/standards/>
- **ISACA COBIT 2019 Framework Overview**
<https://www.isaca.org/resources/cobit>
- **PCAOB Audit Standards**
<https://pcaobus.org/standards/auditing>

◆ PHASE 05 SPECIALISE & JOB HUNT

■ Ongoing

■ *Goal: Pick a GRC lane, get certified, build a portfolio, and land your first role.*

WHAT TO LEARN

■ GRC Career Tracks

- Compliance Analyst · Risk Analyst
- Information Security Analyst (GRC focus)
- Audit Associate · Privacy Analyst

■ Portfolio Projects

- Build a mock risk register in Excel/Notion
- Write a sample IS Policy document
- Map a company to NIST CSF (use a public case study)
- Document a HIPAA or SOC 2 gap analysis

■ Advanced Certs

- CISSP, CISM, CRISC, CDPSE
- ISO 27001 Lead Implementer

TARGET CERTIFICATIONS

- ISACA CISM
- CISSP (5yr exp required)
- CompTIA CySA+

FREE RESOURCES & LINKS

→ **LinkedIn — GRC Jobs Filter**
<https://www.linkedin.com/jobs/governance-risk-compliance-jobs>

→ **ISC2 Community (Free)**
<https://community.isc2.org>

→ **r/cybersecurity — Career Megathread**
<https://www.reddit.com/r/cybersecurity>

→ **Cybersecurity Career Pathway Tool (NICE)**
<https://niccs.cisa.gov/workforce-development/cyber-career-pathways>

→ **GRC Mastery (Paul Proctor Blog)**
<https://www.gartner.com/en/information-technology/topics/governance-risk-compliance>

FULL ROADMAP TIMELINE

Phase	Focus	Duration	Key Cert
01	IT & Security Basics	4–6 wks	ITF+ / Google IT
02	GRC Frameworks	6–8 wks	Security+ / ISC2 CC
03	Risk Management	4–6 wks	—
04	Policies & Auditing	4–5 wks	CISA prep
05	Specialise & Job Hunt	Ongoing	CISM / CISSP
TOTAL		~6 months	GRC Analyst Ready ✓

Remember: GRC is about people, process, and technology — in that order. You don't need to hack to work in cybersecurity. Follow @cyber_crookz for more reels, roadmaps, and free resources. ■